

Active Directory - Interview Q&A

Condensed answers (2-3 lines) for quick revision

Basics

What is Active Directory? What problem does it solve?

AD is Microsoft's directory service for centralized authentication and management of users, computers, and resources on a Windows network. It solves the problem of managing identities at scale, giving single sign-on and centralized policy enforcement instead of per-machine local accounts.

What is a Domain, Tree, and Forest? Difference?

Domain = core admin/security boundary sharing a common database and policies. Tree = domains sharing a contiguous DNS namespace. Forest = top-level boundary of one or more trees sharing a schema and global catalog; the forest, not the domain, is AD's true security boundary.

What is a Domain Controller? Can a domain have multiple DCs?

A DC is a server running AD DS that authenticates users/computers and stores the AD database. Yes, domains should have multiple DCs for fault tolerance, load distribution, and multi-master replication; DCs can also be placed per site for local authentication.

What is an OU? Difference between OU and Security Group?

An OU is a container for organizing objects and applying Group Policy/delegating admin control. A Security Group grants access/permissions to resources. GPOs link to OUs, not directly to groups; a user has one OU but can be in many groups.

What is LDAP? What port does it run on?

LDAP (Lightweight Directory Access Protocol) is used to query/modify the AD database. Runs on port 389 (unencrypted) and 636 for LDAPS (encrypted); Global Catalog queries use 3268/3269.

What is Kerberos? Why does AD use it instead of NTLM?

Kerberos is a ticket-based authentication protocol using a KDC to issue TGTs and service tickets, avoiding sending passwords/hashes repeatedly. It's used over NTLM for mutual authentication, resistance to relay/Pass-the-Hash, and better performance via ticket reuse.

Intermediate

What are FSMO roles? Name all five.

Flexible Single Master Operations - operations too risky for multi-master. Forest-wide: Schema Master, Domain Naming Master. Domain-wide: PDC Emulator, RID Master, Infrastructure Master.

What is Group Policy (GPO)? GPO precedence order (LSDOU)?

GPOs centrally enforce settings across users/computers. Precedence: Local -> Site -> Domain -> OU, with the last applied (innermost OU) winning, unless overridden by Block Inheritance or an Enforced GPO.

What is AD replication? How does it work between DCs?

Replication propagates changes across all DCs using a multi-master model. USNs track deltas, the KCC builds replication topology, intra-site replication is frequent (~15s) and inter-site is scheduled via site links; consistency is eventual, not instant.

What is a Global Catalog? Why is it needed?

A GC is a DC role holding a partial copy of every object across the whole forest, enabling forest-wide search, UPN logon resolution, and Universal Group membership lookups that a normal DC can't provide alone.

What is a Trust relationship? One-way vs two-way, transitive vs non-transitive?

A trust lets users in one domain/forest authenticate to resources in another. One-way = access flows in one direction only; two-way = mutual. Transitive extends trust through a chain (default within a forest); non-transitive is limited to the two domains involved.

What is Tombstone lifetime / AD Recycle Bin?

A tombstone is a stripped placeholder kept for a deleted object (default 180 days) so deletions replicate correctly. AD Recycle Bin (must be enabled) preserves all attributes of deleted objects for full, easy restoration before they tombstone.

What is DNS's role in Active Directory?

AD depends entirely on DNS: clients use SRV records to locate DCs, Kerberos SPNs rely on DNS names, and DC replication partners are found via DNS. Most 'AD problems' are actually DNS misconfigurations.

What is NTDS.dit?

NTDS.dit is the AD database file on every DC, storing all objects and password hashes. It's a top attacker target (via DCSync or physical/backup theft) since it lets offline extraction of every domain credential.

Security-Focused

What is Kerberoasting? Detect/prevent?

Attackers request TGS tickets for SPN accounts (any user can) and crack them offline since tickets are encrypted with the service account's password hash. Detect via Event ID 4769 anomalies/RC4 use; prevent with long random service account passwords or gMSAs, and enforce AES.

Explain Service Principal Name (SPN).

An SPN uniquely maps a service instance on a host to the account running it, so Kerberos knows whose password hash to use when issuing a service ticket. Any SPN-registered account becomes a Kerberoasting target.

What is a Golden Ticket vs Silver Ticket attack?

Golden Ticket forges a TGT using the stolen KRBTGT hash, granting persistent domain-wide access as any user. Silver Ticket forges a TGS using a single service account's hash, limited to that specific service only.

What is KRBTGT?

KRBTGT is a built-in, disabled AD account whose password hash the KDC uses to sign every TGT in the domain. Stealing its hash enables Golden Ticket attacks; the fix is resetting its password twice.

What is Pass-the-Hash?

An attacker authenticates using a stolen NTLM hash directly, without cracking the password, since NTLM treats the hash itself as proof of identity. Mitigated via LAPS, Credential Guard, and tiered admin to limit hash

caching/reuse.

What is NTLM?

NTLM (NT LAN Manager) is Microsoft's legacy challenge-response authentication protocol, superseded by Kerberos. It lacks mutual authentication and is vulnerable to Pass-the-Hash and relay attacks, but remains for legacy compatibility.

What challenge does the server send in NTLM?

A random 8-byte nonce generated per authentication attempt, used to prevent replay of captured responses. It doesn't stop Pass-the-Hash since anyone holding the hash can compute a valid response to any new challenge.

What is LDAP injection?

Attackers inject malicious LDAP filter syntax into unsanitized input (like a login field) to manipulate query logic, similar to SQL injection - can bypass authentication or leak directory data. Prevented via input escaping and parameterized queries.

How do you harden Active Directory?

Layered approach: tiered admin model + PAWs, LAPS + Credential Guard + gMSAs, disable/restrict NTLM, enforce LDAP/SMB signing, rotate KRBTGT periodically, monitor Kerberos/logon anomalies, and audit AD CS templates and privileged group memberships.

What is AD CS and why is it a common attack surface (ESC1-ESC8)?

AD CS is AD's built-in PKI; certificates can substitute for passwords for authentication. ESC1-ESC8 are template/CA misconfigurations (e.g., attacker-controlled SAN, weak template ACLs) letting low-privileged users obtain certs that authenticate as Domain Admins.

What is a DCSync attack?

An attacker with replication rights (Replicating Directory Changes/All) impersonates a DC to pull password hashes via legitimate replication protocol, no code execution on a DC needed - often used to dump KRBTGT for a Golden Ticket.

How would you detect lateral movement in AD?

Correlate behavioral anomalies: one account authenticating to many hosts quickly (4624/4625), abnormal Kerberos ticket requests (4769), privileged accounts on non-Tier-0 machines, unexpected group changes, and DCSync-related 4662 events - tools like Defender for Identity and BloodHound help.

Domain Admin compromise vs single workstation compromise - blast radius?

A workstation compromise is normally contained to that user's access, especially with LAPS/Credential Guard. A Domain Admin compromise grants total domain control (NTDS.dit, DCSync, GPO abuse) and can require a full incident response or domain rebuild.

Scenario-Based

A user can't log in, but their account isn't locked - how do you troubleshoot?

Work layer by layer: check the account (disabled/expired/logon hours) in AD, verify clock sync (Kerberos skew), check DNS resolution and DC connectivity, check replication health, and verify the client machine's secure channel trust with the domain.